Đánh giá và Thực hành Toàn diện về Kiểm thử Xâm nhập Hệ thống

Hoàng Quốc Trọng
Trường Công nghệ Thông tin và Truyền thông
Đại học Bách Khoa Hà Nội
Hà Nội, Việt Nam
trong.hq232093M@sis.hust.edu.vn

Ngô Công Dũng
Trường Công nghệ Thông tin và Truyền thông
Đại học Bách Khoa Hà Nội
Hà Nội, Việt Nam
dung.nc252641M@sis.hust.edu.vn

Đoàn Ngọc Minh
Trường Công nghệ Thông tin và Truyền thông
Đại học Bách Khoa Hà Nội
Hà Nội, Việt Nam
minh.dn251067m@sis.hust.edu.vn

***Tóm tắt nội dung*—Với sự tiến bộ nhanh chóng của công nghệ thông tin, độ phức tạp của các ứng dụng ngày càng tăng, và những thách thức về an ninh mạng mà chúng ta đối mặt cũng đang leo thang. Bài báo này nhằm mục đích nghiên cứu các phương pháp và thực hành kiểm thử xâm nhập bảo mật hệ thống, khám phá cách tăng cường an ninh hệ thống thông qua các quy trình kiểm thử xâm nhập có hệ thống và các phương pháp kỹ thuật. Bài báo cũng xem xét các công cụ xâm nhập hiện có, phân tích điểm mạnh, điểm yếu và các lĩnh vực áp dụng của chúng để hướng dẫn các kiểm thử viên trong việc lựa chọn công cụ. Ngoài ra, dựa trên quy trình kiểm thử xâm nhập được phác thảo trong bài báo này, các công cụ thích hợp được lựa chọn để tái hiện các quy trình tấn công bằng cách sử dụng các phạm vi mục tiêu và máy mục tiêu. Cuối cùng, thông qua phân tích tình huống thực tế, các bài học rút ra từ các cuộc tấn công thành công được tóm tắt để cung cấp thông tin cho nghiên cứu trong tương lai.**

***Index Terms*—kiểm thử xâm nhập, an ninh mạng, quy trình kiểm thử, đánh giá công cụ, tấn công thực nghiệm.**

I. Giới thiệu

Làn sóng tin học hóa hiện nay chắc chắn đã quét qua toàn cầu, đưa con người trên toàn thế giới vào một môi trường xã hội được kết nối mạng và số hóa. Kể từ năm 2018, khoảng 900.000 cá nhân đã lên mạng lần đầu tiên mỗi ngày [30]. Dựa trên tốc độ này, tính đến tháng 6 năm 2024, cơ sở người dùng internet của Trung Quốc chiếm khoảng 78,5% tổng dân số. Cơ sở người dùng internet toàn cầu đã tăng lên mức kỷ lục 5,3 tỷ người. Dự kiến con số này sẽ đạt 6,6 tỷ trên toàn thế giới vào năm 2025. Điều này nhấn mạnh vai trò nòng cốt của internet trong xã hội loài người. Ngoài việc đóng vai trò là cơ sở hạ tầng nền tảng cho sự phát triển kỹ thuật số của Trung Quốc, nó còn tạo thành một biện pháp cơ bản để xây dựng một cộng đồng toàn cầu.

Bên dưới bề mặt của những tiến bộ CNTT nhanh chóng, các cuộc tấn công mạng bất hợp pháp đã âm ỉ từ lâu. Nhiều tội phạm khai thác các kỹ thuật hack để nhắm mục tiêu vào các hệ thống nhằm thu lợi bất hợp pháp. Ví dụ, cuộc tấn công trộm cắp dữ liệu MOVEit Transfer đã khai thác một lỗ hổng dịch vụ truyền tệp, dẫn đến các cuộc tấn công độc hại nhằm vào hơn 2.000 tổ chức và làm lộ hơn 93 triệu hồ sơ người dùng [16]. Nhiều trường hợp tấn công tương tự tồn tại, mỗi trường hợp đại diện cho các hoạt động bất hợp pháp nghiêm trọng xâm phạm nghiêm trọng đến an ninh mạng, gây ra những tổn thất không thể lường trước cho các quốc gia, doanh nghiệp và cá nhân. Việc sử dụng các phương pháp hiệu quả để xác định các rủi ro hệ thống và triển khai các biện pháp phòng thủ tương ứng để bảo vệ các hệ thống mạng và thúc đẩy một môi trường trực tuyến an toàn là điều cấp thiết. Chỉ bằng cách áp dụng quan điểm của kẻ tấn công, chúng ta mới có thể thực hiện đánh giá toàn diện về hệ thống. Đây chính là lý do tại sao kiểm thử xâm nhập ra đời [12].

Nghiên cứu hiện tại chủ yếu chia nó thành kiểm thử thủ công truyền thống và kiểm thử tự động [8]. Tuy nhiên, cả hai về cơ bản đều áp dụng quan điểm của hacker, nhắm vào các lỗ hổng hệ thống và sử dụng tất cả các phương pháp tấn công có thể để cố gắng xâm nhập hệ thống, từ đó đạt được mục tiêu chính là đánh giá bảo mật. Các phương pháp phổ biến bao gồm kiểm thử hộp đen (black-box), hộp trắng (white-box) và hộp xám (gray-box), như được nêu chi tiết trong các chương tiếp theo. Các triển khai cụ thể phụ thuộc vào yêu cầu của người kiểm thử, cho dù là đánh giá từ bên trong hay bên ngoài mạng doanh nghiệp, hoặc đánh giá bảo mật cho các mục tiêu như hệ điều hành và cơ sở dữ liệu. Các nhóm kiểm thử sử dụng các phương pháp có tính mục tiêu cao để phát hiện các lỗ hổng hệ thống, cuối cùng biên soạn danh sách lỗ hổng chi tiết và các chiến lược khắc phục trong các báo cáo. Điều này loại bỏ các lỗ hổng, giảm thiểu các mối đe dọa bảo mật tiềm ẩn và tăng cường khả năng phòng thủ của hệ thống [6]. Bài báo này giới thiệu toàn diện nội dung và vai trò của kiểm thử xâm nhập, phân tích và tóm tắt các phương pháp kiểm thử xâm nhập hiện có, thiết kế và tối ưu hóa quy trình kiểm thử xâm nhập hiện tại, cung cấp các tiêu chuẩn tham chiếu cho các nhóm kiểm thử để lựa chọn các công cụ kiểm thử hiệu quả, và cho phép chúng ta hiểu sâu sắc về kiểm thử xâm nhập thông qua các thực nghiệm tái hiện tấn công liên quan.

Tóm lại, nghiên cứu kiểm thử xâm nhập hiện nay trên toàn thế giới thể hiện ba đặc điểm chính: trí tuệ, tính thực tiễn và tính tuân thủ. Ở trong nước, các động lực chính sách thúc đẩy đổi mới công nghệ. Trên quốc tế, trọng tâm nghiêng về hệ

sinh thái mã nguồn mở và triển khai kiến trúc zero-trust.

Bài báo này thực hiện một nghiên cứu toàn diện về đánh giá an ninh và thực hành trong kiểm thử xâm nhập hệ thống. Đầu tiên, bài báo xem xét các phương pháp cốt lõi và các công cụ phổ biến của kiểm thử xâm nhập. Sau đó, một quy trình kiểm thử xâm nhập tiêu chuẩn được thiết kế và xác thực thông qua các thực nghiệm trên cả hệ thống máy chủ và ứng dụng web. Cuối cùng, dựa trên nhiều nghiên cứu tình huống thực tế, bài báo tóm tắt các hiểu biết sâu sắc về phòng thủ để đối phó với các cuộc tấn công mạng hiện đại.

Các đóng góp chính của nghiên cứu này là:

- **Tối ưu hóa và Tiêu chuẩn hóa Thiết kế Quy trình Kiểm thử Xâm nhập:** Dựa trên việc xem xét toàn diện các phương pháp hiện có, chúng tôi thiết kế và trình bày quy trình kiểm thử xâm nhập sáu giai đoạn, tối ưu hóa mọi giai đoạn từ thu thập thông tin đến kiểm thử lại báo cáo.
- **Xây dựng và Ứng dụng Mô hình Đánh giá Định lượng dựa trên Công cụ:** Chúng tôi đề xuất ba quy trình phân bổ trọng số cung cấp các tiêu chí tham chiếu khách quan cho việc lựa chọn và kết hợp công cụ trong các kịch bản kiểm thử khác nhau thông qua các tính toán trọng số.
- **Xác thực Thực nghiệm và Phân tích Kiểm thử Xâm nhập Đa chiều:** Chúng tôi tái hiện các cuộc tấn công xâm nhập máy chủ nhắm vào hệ thống Windows và Linux, cũng như các thực nghiệm xâm nhập web như SQL injection và tải tệp lên dựa trên DVWA.
- **Phân tích và Hiểu biết sâu sắc từ các Trường hợp An ninh Mạng Thực tế:** Chúng tôi phân tích các sự cố bảo mật lớn trong những năm gần đây để xác định các yếu tố chính góp phần vào các cuộc tấn công thành công và các lỗ hổng trong phòng thủ. Phân tích này cung cấp hướng dẫn trực tiếp để nâng cao mức độ bảo vệ an ninh trong các lĩnh vực liên quan.

Nghiên cứu này nhằm cung cấp hướng dẫn toàn diện cho các thực hành kiểm thử xâm nhập, từ các phương pháp lý thuyết đến lựa chọn công cụ và xác thực thực nghiệm, từ đó nâng cao khả năng phòng thủ chủ động của các hệ thống thông tin.

II. Kiến thức nền tảng

A. Các mối đe dọa lớn đối với hệ thống mạng

1) Tấn công Kỹ thuật Xã hội: Các cuộc tấn công kỹ thuật xã hội dựa trên việc khai thác các lỗ hổng của con người, bao gồm sự đồng cảm, sự tin tưởng, nỗi sợ hãi và lòng tham, thông qua thao túng tâm lý để xúi giục người dùng tiết lộ thông tin hoặc thực hiện các hành động độc hại [15]. Bản chất của chúng không nằm ở việc khai thác các lỗi kỹ thuật, mà ở việc nhắm vào tâm lý và hành vi của con người, thúc giục nạn nhân tự nguyện hợp tác với những kẻ tấn công. Tỷ lệ thành công của chúng đạt tới 90%. Các hình thức điển hình bao gồm email lừa đảo (phishing), trang web giả mạo và lừa đảo qua điện thoại. Ví dụ, email lừa đảo có thể giả dạng là các thông báo "đáng tin cậy"từ ngân hàng, công ty hoặc bạn bè, lừa người dùng nhấp vào các liên kết độc hại trong tệp đính kèm hoặc nhập thông tin nhạy cảm như mật khẩu tài khoản [7]. Khi thành công, kẻ tấn công có thể thu được một lượng lớn thông tin cá nhân, ép buộc nạn nhân chuyển tiền hoặc trả tiền chuộc, mở đường cho các cuộc tấn công tiếp theo như mã hóa tống tiền (ransomware) và khai thác danh tính của nạn nhân để gian lận thêm. Do các cuộc tấn công này khai thác các lỗ hổng của con người, các biện pháp phòng thủ bao gồm tăng cường quy trình xác thực, duy trì sự cảnh giác cao độ, thường xuyên cập nhật hệ thống và mật khẩu, và cải thiện đào tạo an ninh cho nhân viên đối với các doanh nghiệp [11].

2) Giả mạo Danh tính: Giả mạo danh tính đề cập đến việc những kẻ tấn công sử dụng các phương tiện kỹ thuật để mạo danh người dùng hợp pháp nhằm vượt qua các cơ chế bảo mật, có được quyền truy cập trái phép hoặc thực hiện các cuộc tấn công độc hại. Nó thường được phân loại thành giả mạo IP và giả mạo người dùng. Giả mạo IP liên quan đến việc những kẻ tấn công sử dụng địa chỉ IP của người dùng hợp pháp hoặc địa chỉ IP không tồn tại làm IP nguồn cho các gói tin chúng gửi [22]. Điều này khai thác thực tế là các giao thức liên quan không xác minh IP nguồn của các gói tin để thực hiện các cuộc tấn công. Giả mạo người dùng có thể đạt được bằng cách tạo ra các hình ảnh khuôn mặt, mẫu giọng nói và các tài liệu nhận dạng như thẻ ID cực kỳ chân thực thông qua Mạng Đối kháng Tạo (GAN) và Các Mô hình Ngôn ngữ Lớn (LLM), từ đó cho phép tạo ra người dùng giả. Ngoài ra, các công cụ như trạm phát sóng giả hoặc Wi-Fi lừa đảo có thể được sử dụng để chặn mã xác minh SMS. Sau đó, chúng được kết hợp với các tập lệnh tự động để thực hiện các giao dịch gian lận, chiếm đoạt tài khoản và các hoạt động khác. Các cuộc tấn công như vậy đã phát triển thành một chuỗi công nghiệp hoàn chỉnh trải dài từ phát triển công cụ đến buôn bán dữ liệu. Để chống lại các cuộc tấn công giả mạo này, các kỹ thuật phát hiện sự sống động (liveness detection) như chớp mắt và há miệng thường được sử dụng để xác minh danh tính. Ngoài ra, phân tích thời gian thực các mẫu chuyển động của chuột được sử dụng để phân biệt giữa người dùng AI và người dùng thực bằng cách theo dõi các quỹ đạo hoạt động của họ [29].

3) Mã độc: Mã độc đề cập đến các bộ lệnh do những kẻ tấn công dàn dựng để giám sát, chiếm quyền điều khiển hoặc phá hoại các hệ thống hoặc chương trình [23]. Trọng tâm chính của nó là sự che giấu để trốn tránh các cơ chế phát hiện an ninh, trong khi khả năng tấn công là thứ yếu. Nó chủ yếu được phân loại thành các loại độc lập và tự sao chép. Loại trước sở hữu đầy đủ chức năng của chương trình và có thể thực thi và lan truyền độc lập mà không cần vật chủ, trong khi loại sau thường bao gồm các đoạn mã yêu cầu một vật chủ để lan truyền và chạy. Các danh mục cụ thể được hiển thị trong Bảng I.

Bảng I: Specific Categories

Phân loại	Cụ thể
Mã độc không độc lập tự sao chép	Virus
Mã độc không độc lập không tự sao chép	Backdoor
Mã độc độc lập tự sao chép	Worm
Mã độc độc lập không tự sao chép	Trojan

4) Xâm nhập từ xa: Xâm nhập từ xa đề cập đến việc những kẻ tấn công khai thác các phương tiện kỹ thuật qua mạng để thực hiện các hành động trái phép như truy cập từ xa, điều khiển hoặc phá hoại các hệ thống mục tiêu [25]. Cuộc tấn công này có thể được phân loại rộng rãi thành hai loại: truy cập trái phép và truy cập bất hợp pháp. Truy cập trái phép liên quan đến việc những kẻ tấn công sử dụng các phương pháp kỹ thuật kết hợp với các công cụ hack khác nhau để vượt qua các cơ chế bảo mật, chẳng hạn như xác thực danh tính, và giành được quyền truy cập bất hợp pháp vào các hệ thống mục tiêu. Truy cập bất hợp pháp đề cập đến việc những kẻ tấn công thiết lập các kết nối trái phép với các hệ thống nội bộ thông qua các kênh bất hợp pháp để đạt được quyền truy cập vào các tài nguyên hệ thống.

5) Tấn công Từ chối Dịch vụ Phân tán (DDoS): Tấn công Từ chối Dịch vụ Phân tán (DDoS) tận dụng nhiều thiết bị để tiêu thụ lượng lớn tài nguyên hệ thống mục tiêu thông qua các phương pháp tấn công cụ thể, gây ra tình trạng tê liệt máy chủ và khiến nó không thể cung cấp các dịch vụ bình thường [14]. Những kẻ tấn công khai thác các lỗ hổng bảo mật cố hữu trong các giao thức để gửi một lượng lớn các gói dữ liệu rác được thiết kế cẩn thận, trông có vẻ hợp pháp đến các máy chủ mục tiêu. Các gói tin này vượt qua thành công sự phát hiện của tường lửa, cuối cùng làm cạn kiệt tài nguyên của hệ thống mục tiêu và chấm dứt các dịch vụ của nó. Rõ ràng, việc phòng thủ chống lại các cuộc tấn công như vậy đặt ra những thách thức đáng kể.

6) Trộm cắp và Giả mạo Thông tin: Trong lĩnh vực an ninh thông tin, trộm cắp và giả mạo thông tin là những phương thức tấn công điển hình [21]. Dựa trên đặc điểm của chúng, các cuộc tấn công này có thể được phân loại thành tấn công thụ động và chủ động. Các hình thức phổ biến của tấn công thụ động bao gồm nghe trộm phiên (session eavesdropping), phân tích lưu lượng và tấn công xen giữa (man-in-the-middle), chủ yếu được sử dụng để lấy quyền riêng tư của người dùng, bí mật thương mại hoặc thông tin xác thực hệ thống. Vì các cuộc tấn công này thường chỉ liên quan đến việc chặn nội dung truyền thông mà không sửa đổi dữ liệu, nên chúng có tính che giấu cao và khó phát hiện. Ngược lại, các cuộc tấn công chủ động thường sử dụng các kỹ thuật như gói tin giả mạo, phát lại phiên (session replay) và giả mạo độc hại để giành quyền truy cập trái phép vào các hệ thống [27]. Do đó, phòng thủ chống lại các tấn công thụ động tập trung vào ngăn ngừa hơn là phát hiện, dựa vào mã hóa và kiểm soát truy cập để bảo vệ thông tin. Tuy nhiên, các tấn công chủ động yêu cầu sự kết hợp của phát hiện xâm nhập và chữ ký số để phòng thủ động.

B. Các phương pháp kiểm thử xâm nhập chính

Dựa trên mục tiêu kiểm thử và cách thức triển khai, các phương pháp kiểm thử xâm nhập chủ đạo có thể được phân loại thành kiểm thử hộp đen, kiểm thử hộp trắng và kiểm thử hộp xám, hình thành các khung tiêu chuẩn hóa như OSSTMM và PTES [1].

(1) Kiểm thử Hộp đen (Black-Box Testing): Phương pháp này nhấn mạnh tính thực tế, trong đó người kiểm thử hoạt động hoàn toàn từ quan điểm của một kẻ tấn công bên ngoài với kiến thức tối thiểu về mục tiêu. Họ chỉ dựa vào thông tin công khai về hệ thống. Ưu điểm nằm ở sự phù hợp chặt chẽ với các kịch bản tấn công thực tế, trong khi nhược điểm là sự đầu tư thời gian đáng kể và khả năng bỏ lỡ các lỗ hổng cao hơn.

(2) Kiểm thử Hộp trắng (White-Box Testing): Được thực hiện từ bên trong hệ thống mục tiêu, phương pháp này phản ánh quan điểm của người phát triển hệ thống [17]. Kiểm thử diễn ra sau khi có được kiến thức toàn diện về hệ thống, chẳng hạn như thông tin nhân viên và dữ liệu bảo mật. Phương pháp này nhanh hơn và cung cấp khả năng phát hiện lỗ hổng triệt để hơn, hầu như loại bỏ rủi ro bỏ lỡ lỗ hổng. Tuy nhiên, nó phát sinh chi phí cao hơn.

(3) Kiểm thử Hộp xám (Gray-Box Testing): Kết hợp các tính năng của hai phương pháp trước, phương pháp này liên quan đến việc người kiểm thử hoạt động với thông tin đăng nhập của người dùng với quyền truy cập dữ liệu một phần, cho phép họ có được thông tin hạn chế về cơ sở hạ tầng mạng. Phương pháp này hiệu quả và tiết kiệm chi phí hơn kiểm thử hộp đen trong khi tránh được chi phí cao của kiểm thử hộp trắng.

Hiện nay, theo khung phân loại này, kiểm thử xâm nhập được chia nhỏ hơn nữa thành kiểm thử xâm nhập truyền thống và kiểm thử xâm nhập tự động.

C. Tiến trình nghiên cứu hiện tại và thách thức

Khi các công nghệ như LLM và học sâu phát triển, chúng đã được chứng minh là tăng cường nhận dạng lỗ hổng tự trị và độ chính xác của việc tạo lộ trình tấn công tự động [33]. Việc tiêu chuẩn hóa các quy trình kiểm thử xâm nhập và tích hợp các công cụ kiểm thử chính yếu đã dần trở thành sự đồng thuận trong ngành. Ví dụ, việc áp dụng rộng rãi khung PTES gián tiếp thúc đẩy sự tiêu chuẩn hóa trong các giai đoạn kiểm thử như thu thập thông tin, khai thác lỗ hổng và sau khai thác.

Dù có những tiến bộ này, kiểm thử xâm nhập vẫn đối mặt với nhiều thách thức: (1) Các công cụ quét lỗ hổng hiện tại phụ thuộc nhiều vào cơ sở dữ liệu lỗ hổng đã biết (như CVE), hạn chế khả năng phát hiện các lỗ hổng zero-day. (2) Sự phát triển liên tục của các công nghệ IoT và 5G dẫn đến môi trường kiểm thử ngày càng đa dạng và phức tạp. (3) Thiếu các giải pháp kiểm thử hoàn thiện cho các vectơ tấn công mới như lỗ hổng hợp đồng thông minh blockchain.

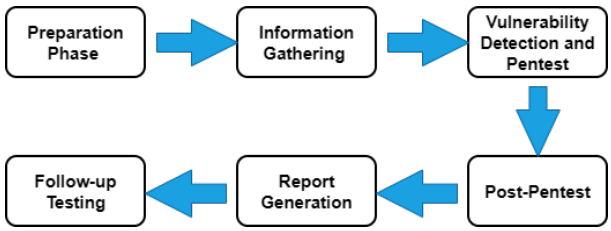
III. Thiết kế quy trình kiểm thử xâm nhập

A. Thiết kế quy trình tổng thể

Dựa trên các yêu cầu cụ thể đối với kiểm thử xâm nhập mạng được nêu trong Tiêu chuẩn Bảo vệ Cấp độ 2.0 và các khung quy trình kiểm thử xâm nhập hiện có, quy trình kiểm thử xâm nhập cơ bản có thể được thiết kế thành sáu giai đoạn được minh hoạ trong Hình 1: (1) Giai đoạn chuẩn bị, (2) Thu thập thông tin, (3) Phát hiện lỗ hổng và Kiểm thử xâm nhập, (4) Kiểm thử sau xâm nhập, (5) Tạo báo cáo, và (6) Kiểm thử lại và Kết thúc.

B. Mô tả chi tiết các giai đoạn

1) Chuẩn bị và Thu thập thông tin: Sau khi nhận được sự cho phép liên quan từ khách hàng, nhóm kiểm thử phải thảo



Hình 1: Quy trình kiểm thử xâm nhập

Hình 2: Các mục thu thập thông tin

luận kỹ lưỡng các chi tiết kiểm thử với khách hàng để xác định mục tiêu, các ràng buộc và phạm vi kiểm thử. Điều này đảm bảo đạt được kết quả mong muốn của khách hàng và cho phép xây dựng một kế hoạch kiểm thử cụ thể. Ngoài ra, vì kiểm thử xâm nhập có thể gây ra một số thiệt hại cho hệ thống mục tiêu và liên quan đến các rủi ro tiềm ẩn, khách hàng phải được thông báo về những khả năng đó. Nhóm nên hỗ trợ khách hàng sao lưu dữ liệu quan trọng. Tóm lại, khách hàng phải nhận thức đầy đủ về tất cả các chi tiết liên quan đến quy trình kiểm thử xâm nhập.

Mục tiêu chính của thu thập thông tin là có được càng nhiều thông tin hữu ích càng tốt, bao gồm kiến trúc và chức năng hệ thống, các biện pháp bảo mật, người dùng và quyền hạn, cấu trúc mạng, các cổng mở, phần mềm của bên thứ ba và các dịch vụ như được thể hiện trong Hình 2. Giai đoạn này có thể kết hợp các cuộc tấn công kỹ thuật xã hội để đánh giá nhận thức bảo mật của nhân viên doanh nghiệp và sự cảnh giác của nhân viên nội bộ đối với việc rò rỉ thông tin nhạy cảm. Hiện nay, việc thu thập thông tin chủ yếu sử dụng các phương pháp sau: kỹ thuật xã hội, thu thập thông tin công khai, quét mạng và các phương pháp khác.

2) Phát hiện lỗ hổng và Kiểm thử xâm nhập: Quét lỗ hổng là quá trình sử dụng các công cụ như Nessus để xác định các lỗ hổng hệ thống và các điểm yếu khác. Tiếp theo, nhóm kiểm thử sử dụng kiến thức chuyên môn để đánh giá các lỗ hổng này và xác định các điểm yếu thực sự trong hệ thống. Sau đó, họ thực hiện các cuộc tấn công hacker mô phỏng thực tế nhằm vào các lỗ hổng đã xác định để đánh giá khả năng phòng thủ của hệ thống và khả năng phục hồi sau tấn công [19]. Do đó, kiểm thử xâm nhập xác định các điểm yếu của hệ thống và các khu vực cần cải thiện, nâng cao khả năng phòng thủ và khả năng phục hồi sau các cuộc tấn công của hacker. Ngoài ra, nó nâng cao nhận thức về bảo mật của nhân viên tại tổ chức được kiểm thử và rèn luyện các kỹ năng kỹ thuật của nhân viên kiểm thử. Nó có thể được phân loại rộng rãi thành ba loại: Kiểm thử xâm nhập mạng, Kiểm thử xâm nhập ứng dụng và Kiểm thử xâm nhập vật lý.

3) Kiểm thử sau xâm nhập: Kiểm thử sau xâm nhập xảy ra sau khi giành được quyền truy cập hệ thống hoặc quyền quản trị viên miền. Dựa trên đặc điểm kinh doanh của tổ chức mục tiêu, nhóm kiểm thử lập bản đồ và xác định các thông tin quan trọng và tài sản kỹ thuật số của tổ chức, phát hiện các vectơ tấn công có khả năng gây ra thiệt hại và tác động đáng kể. Sau khi đạt được các mục tiêu như có được các quyền liên quan và thông tin quan trọng hoặc xâm nhập hệ thống mục tiêu, nhóm kiểm thử phải dọn dẹp chiến trường bằng cách loại bỏ các dấu vết xâm nhập, chẳng hạn như xóa phần mềm độc hại đã tải lên và xóa nhật ký hệ thống.

Kiểm thử sau xâm nhập yêu cầu cả leo thang đặc quyền và duy trì đặc quyền, làm cho việc kiểm soát đặc quyền trở thành bản chất của kiểm thử xâm nhập. Từ các góc độ phòng thủ quyền lợi và leo thang đặc quyền, có những sự khác biệt rõ rệt giữa hệ thống Windows và Linux. Trên Windows, duy trì đặc quyền thường bao gồm các phương pháp như tự động khởi chạy dịch vụ, chiếm đoạt COM và backdoor WMI. Trên Linux, các kỹ thuật duy trì bao gồm liên kết tượng trưng (symbolic links), backdoor và truy cập khóa công khai/riêng tư SSH không cần mật khẩu.

4) Báo cáo và Kết thúc: Giai đoạn này yêu cầu chuẩn bị các báo cáo kiểm thử chi tiết ghi lại trung thực các phương pháp tấn công được sử dụng trong mỗi giai đoạn kiểm thử, các công cụ liên quan được sử dụng, và thiệt hại cũng như tác động của các cuộc tấn công này đối với hệ thống. Nó nên giải thích các chi tiết cụ thể về việc phát hiện lỗ hổng, phác thảo các phương pháp đánh giá, chỉ rõ các rủi ro liên quan và cung cấp các khuyến nghị khắc phục có mục tiêu để hỗ trợ bên được kiểm thử trong việc loại bỏ các lỗ hổng bảo mật và nâng cao khả năng bảo vệ của họ.

IV. Giải pháp kiểm thử xâm nhập tự động AutoScanCVE

A. Cách tiếp cận và Quy trình hoạt động

AutoScanCVE được đề xuất là một công cụ tự động hoá quy trình dò quét và phát hiện lỗ hổng bảo mật dựa trên CVE mapping. Quy trình hoạt động của hệ thống bao gồm các bước sau:

1) **Reconnaissance**: Người dùng nhập mục tiêu (IP/-Domain). Hệ thống tự động thực hiện tìm kiếm subdomain, quét cổng, thu thập URL và phản hồi HTTP.
2) **Detection**: Phân tích dữ liệu thu thập để nhận diện công nghệ và phiên bản ứng dụng.
3) **CVE Service**: Ánh xạ công nghệ nhận diện được với cơ sở dữ liệu lỗ hổng (NVD) để tạo danh sách các mục tiêu có khả năng tồn tại lỗ hổng.

4) **Exploitation**: Người dùng chọn mã khai thác phù hợp và thực thi trên mục tiêu. Hệ thống hỗ trợ mở listener và ghi lại C2 session.
5) **Reporting**: Toàn bộ kết quả được lưu trữ và xuất thành báo cáo phục vụ phân tích.

B. Công nghệ sử dụng

Công cụ được thiết kế theo mô hình plugin portable giúp dễ dàng tích hợp. Các công nghệ chính được sử dụng bao gồm:

Bảng II: Công nghệ sử dụng trong AutoScanCVE

Thành phần	Công nghệ
Web Framework	Flask (Blueprint pattern)
HTTP Client	requests (Session & User-Agent)
DNS Resolution	dnspython
Đa luồng	concurrent.futures.ThreadPoolExecutor
Cơ sở dữ liệu	SQLite (sqlite3)
Scheduler	Thư viện schedule + daemon thread
Detection Rules	JSON với regex patterns

C. Các Module Chính

(1) Module cấu hình (PluginConfig): Quản lý tham số hệ thống như timeout HTTP (mặc định 8s), delay (500-800ms) và số thread (tối đa 20).

(2) Module nhận dạng (Product/Version Identification): Thu thập tối thiểu 3 HTTP request (trang chủ, trang 404 giả, website probe) và khớp quy tắc dựa trên headers (độ tin cậy 90%) và nội dung HTML (độ tin cậy 80%).

(3) Bộ Quét Nâng Cao (Advanced Scanner): Bao gồm SubdomainScanner (DNS bruteforce) và DirectoryScanner (HTTP bruteforcing tương tự Gobuster).

(4) Module Giám Sát (Tracking System): Giám sát mục tiêu định kỳ với SQLite persistence, so sánh kết quả để phát hiện các sự kiện thay đổi.

V. Đánh giá công cụ và xác thực thực nghiệm

A. Các công cụ kiểm thử chủ đạo

1) Nền tảng tích hợp và công cụ quét: **(1) Kali Linux:** Được phát hành vào năm 2013 như một bản phân phối Linux dựa trên Debian được phát triển và duy trì bởi nhóm Offensive Security [10]. Kali Linux chuyên về an ninh mạng, phục vụ chủ yếu cho việc kiểm thử xâm nhập và kiểm toán an ninh. Nó tích hợp hơn 600 công cụ kiểm thử xâm nhập, hoạt động như một bộ công cụ và kho vũ khí cho các nhà nghiên cứu bảo mật.

(2) Nmap: Network Mapper (Nmap) là một công cụ kiểm tra và phát hiện mạng mã nguồn mở được Gordon Lyon phát hành lần đầu vào năm 1997. Trong kiểm thử xâm nhập, nó thường được sử dụng trong giai đoạn thu thập thông tin để xác định các máy chủ trực tuyến, các cổng mở và các dịch vụ liên quan.

(3) Masscan: Được phát triển để vượt qua các nút thắt cổ chai về hiệu suất trong các công cụ quét truyền thống, Masscan thực hiện các cuộc quét toàn mạng một cách nhanh chóng. Nó tận dụng việc truyền gói tin song song của CPU đa nhân, đạt đến đỉnh cao lý thuyết là 10 triệu gói mỗi giây.

(4) Shodan: Shodan là một công cụ tìm kiếm được sử dụng chủ yếu để tìm các thiết bị kết nối mạng internet. Nó liên tục quét các địa chỉ IPv4/IPv6 toàn cầu, lập chỉ mục thông tin biểu ngữ từ các thiết bị IoT, máy chủ, hệ thống công nghiệp bị lộ.

2) Công cụ quản lý và khai thác lỗ hổng: **(1) Nessus:** Nessus là một công cụ quản lý lỗ hổng tiêu chuẩn được phát triển bởi Tenable Network Security, chuyên xác định toàn diện các rủi ro bảo mật trên các tài sản mạng. Nó tích hợp hơn 20.000 lỗ hổng, bao gồm các lỗi CVE, lỗi cấu hình, mật khẩu yếu và các bản vá còn thiếu.

(2) OpenVAS: OpenVAS là một khung quản lý và quét lỗ hổng mã nguồn mở phát triển từ mã nguồn Nessus ban đầu. Nó tập trung vào việc cung cấp khả năng phát hiện lỗ hổng cấp doanh nghiệp và chủ yếu được duy trì bởi Greenbone Networks.

(3) Metasploit: Metasploit là một khung kiểm thử xâm nhập mã nguồn mở, ban đầu được phát hành bởi H.D. Moore vào năm 2003. Mục đích chính của nó là tiêu chuẩn hóa quy trình khai thác thông qua thiết kế mô-đun, bao quát toàn bộ chuỗi tấn công từ phát hiện lỗ hổng đến khai thác và leo thang đặc quyền.

3) Công cụ kiểm thử ứng dụng web: **(1) Burp Suite:** Burp Suite là một nền tảng toàn diện được phát triển bởi PortSwigger chủ yếu để kiểm thử xâm nhập web, với chức năng cốt lõi là proxy đánh chặn. Các tính năng của nó bao gồm đánh chặn thời gian thực và sửa đổi các yêu cầu và phản hồi HTTP.

(2) SQLMap: SQLMap là một công cụ kiểm thử xâm nhập mã nguồn mở chuyên về phát hiện và khai thác SQL injection tự động. Nó tập trung vào một công cụ phân tích tham số và khai thác thông minh cao, được sử dụng rộng rãi trong kiểm thử bảo mật cơ sở dữ liệu.

B. Mô hình đánh giá hiệu quả công cụ dựa trên kịch bản

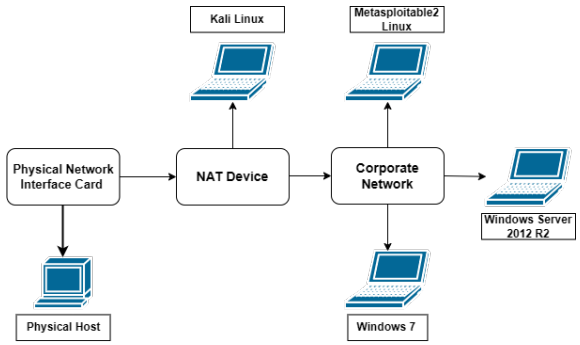
Trong kiểm thử xâm nhập thực tế, các công cụ được sử dụng thay đổi tùy theo mục tiêu kiểm thử và hoàn cảnh cụ thể. Bài báo này đề xuất các kịch bản phân bổ trọng số phù hợp cho ba tình huống khác nhau:

- **Kịch bản 1 (Cân bằng):** Phù hợp cho kiểm thử xâm nhập định kỳ, cân bằng giữa phát hiện lỗ hổng, khai thác và quét cơ bản.
- **Kịch bản 2 (Đánh giá nội bộ doanh nghiệp):** Ưu tiên xác định các lỗ hổng mạng nội bộ và các ứng dụng web nội bộ.
- **Kịch bản 3 (Thực chiến):** Tập trung vào việc khai thác lỗ hổng để giành quyền kiểm soát hệ thống và tính ẩn bản.

Mô hình tính toán tổng trọng số cho mỗi công cụ giúp hỗ trợ người kiểm thử trong việc chọn ra bộ công cụ hiệu quả nhất cho từng kịch bản cụ thể.

C. Thực nghiệm kiểm thử xâm nhập máy chủ

1) Môi trường thực nghiệm và thu thập dữ liệu: Thực nghiệm kiểm thử xâm nhập máy chủ được thực hiện trên môi trường ảo hóa Oracle VM VirtualBox, trong đó một máy vật



Hình 3: Mô hình mạng thực nghiệm kiểm thử xâm nhập máy chủ

lý được sử dụng để triển khai 4 máy chủ thử nghiệm chạy các hệ điều hành khác nhau (Kali Linux 2025.3, Windows 7, Windows Server 2012 R2, Metasploitable 2 Linux). Mô hình mạng được minh họa tại Hình 3.

(1) Quét máy chủ - Host Scanning: Trong giai đoạn thu thập thông tin, máy tấn công thực hiện quét host bằng ba phương pháp khác nhau:

- Lệnh `nmap -sn [target IP]` để phát hiện các host đang hoạt động.
- Sử dụng module `arp_sweep` hoặc `udp_sweep` trong Metasploit để quét ARP trên mạng LAN.
- Sử dụng lệnh `ping` thông thường.

(2) Xác định hệ điều hành - Operating System Identification: Sau khi xác định được các host mục tiêu, quá trình xác định hệ điều hành được thực hiện bằng lệnh `nmap -O` (có thể bổ sung tham số `-sV` hoặc `-A` để thu thập thêm thông tin chi tiết).

(3) Quét cổng và phân tích kết quả - Port Scanning and Analysis of Scanning Results: Tiếp theo, máy tấn công tiến hành quét cổng bằng Nmap để thu thập thông tin chi tiết về các cổng mở và dịch vụ đang chạy. Kết quả quét cho thấy:

- Máy Windows 7 mở cổng 21 (FTP), 80 (Microsoft IIS httpd 7.5), 135 (MSRPC), 139 (NetBIOS), 455 (microsoft-ds)
- Máy Windows Server 2012 R2 mở cổng 135, 139 và 445
- Máy Linux Metasploitable 2 mở nhiều cổng quan trọng như 21 (vsftpd 2.3.4), 22 (OpenSSH), 23 (Telnet), 25 (Smtp), 80 (Apache httpd 2.2.8), 139 (Samba), 3306 (MySQL) và 5432 (PostgreSQL)

Những thông tin này cung cấp nền tảng quan trọng để xác định các vector tấn công tiềm năng.

(4) Quét lỗ hổng - Vulnerability Scanning: Sau khi thu thập đầy đủ thông tin, giai đoạn quét lỗ hổng được thực hiện bằng công cụ Nessus với module Advanced Scan. Kết quả quét được hiện thị trong bảng III. Các lỗ hổng quan trọng được ghi nhận bao gồm CVE-2019-0708 (BlueKeep RDP), MS17-010 (EternalBlue SMB), Samba Badlock, VNC Server default password, và Apache Tomcat AJP Connector Request Injection. Những kết quả này xác nhận rõ ràng sự tồn tại của nhiều lỗ hổng nghiêm trọng trên các hệ thống mục tiêu.

Bảng III: Thống kê lỗ hổng theo máy chủ

Host	Critical	High	Medium	Low	Info
Windows Server 2012 R2	1	0	1	1	35
Windows 7	5	4	11	2	54
Metasploitable2	10	6	24	9	139

2) Tấn công hệ thống Windows: Cuộc tấn công nhắm vào lỗ hổng CVE-2019-0708 (BlueKeep) và MS17-010 (EternalBlue) trên Windows 7. Kết quả cho thấy kẻ tấn công có thể giành quyền kiểm soát toàn bộ hệ thống hoặc gây ra lỗi màn hình xanh.

(1) CVE-2019-0708 (RDP): Lỗ hổng nghiêm trọng trong giao thức Remote Desktop Protocol, CVSS 9.8. Cho phép kẻ tấn công gửi gói tin độc hại gây tràn bộ nhớ và chiếm quyền điều khiển hệ thống. Trong Metasploit, dùng search 0708, chọn module, cấu hình và chạy tấn công. Kết quả là kẻ tấn công có thể giành quyền kiểm soát hệ thống Windows 7.

(2) MS17-010 (EternalBlue): Lỗ hổng thực thi mã từ xa trong SMB (port 445). Trong Metasploit, tìm module $ms17-010$, chọn payload $windows/x64/meterpreter/reverse_tcp$, cấu hình rhost và lhost, sau đó exploit để mở phiên Meterpreter. Trong Meterpreter có thể chạy nhiều lệnh như `sysinfo`, `screen_spy`, `keyscan_start`. Thí nghiệm còn dùng lệnh `shutdown -s -m [target IP] -t 6 -f` để ép máy tắt sau 6 giây.

3) Tấn công hệ thống Linux: Khai thác các lỗ hổng như "VNC Server password", "Samba Badlock"và "Apache Tomcat AJP Connector"để giành quyền truy cập và thực thi lệnh từ xa.

(1) VNC Server "password" Password: Dịch vụ VNC mặc định chạy trên port 5900. Dùng Hydra brute-force để lấy mật khẩu, sau đó kết nối bằng `vncviewer [target IP]`.

(2) Samba Badlock Vulnerability: Lỗ hổng trong giao thức Samba. Trong Metasploit, tìm module $usermap_script$, cấu hình rhosts, chọn payload $cmd/unix/reverse$, rồi chạy để khai thác thành công.

(3) Apache Tomcat AJP Connector Request Injection: Dịch vụ Tomcat chạy trên port 8180. Trong Metasploit, tìm module $tomcat_mgr_login$, cấu hình tốc độ brute-force BRUTEFORCE_SPEED 3, đặt rhosts, RPORT 8180, THREADS 10 để chạy nhiều kết nối song song. Kết quả tấn công thành công.

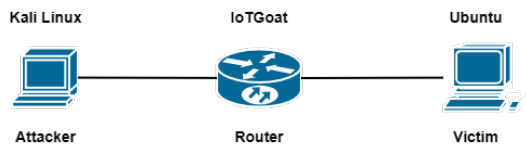
D. Thực nghiệm kiểm thử xâm nhập ứng dụng web

1) Lỗ hổng tải tệp lên (File Upload): Chức năng upload/download là cần thiết trong web app, nhưng nếu không kiểm soát tốt sẽ bị lợi dụng để tải lên webshell (PHP, ASP, JSP).

Kẻ tấn công thường chỉnh sửa form GET để vượt qua kiểm tra, sau đó có thể thực thi lệnh từ xa và duy trì quyền kiểm soát lâu dài.

Trong DVWA:

- Low security: không kiểm tra loại/kích thước file, upload tự do.



Hình 4: Mô hình mạng thực nghiệm kiểm thử xâm nhập IoT

- Medium security: chỉ cho phép JPEG/PNG. Có thể dùng Burp Suite để chặn gói HTTP, chỉnh `Content-Type` thành `image/jpeg` để bypass và upload thành công.

2) Tấn công SQL Injection: Nguyên lý là chèn mã SQL độc hại vào input để thay đổi logic truy vấn, vượt qua xác thực và thao tác dữ liệu. Các kỹ thuật thường dùng là đóng dấu nháy đơn, union query, blind injection.

Thực nghiệm DVWA:

- Nhập 1 lỗi cho thấy tham số id truyền qua GET, dùng MySQL, nối trực tiếp input vào query.
- Dùng `order by` để xác định số cột.
- Dùng `union select` để liệt kê bảng (user, guestbook) và cột (user, password).
- Trích xuất dữ liệu người dùng, giải mã MD5 để đăng nhập thành công.

3) Tấn công XSS: Nguyên lý là chèn mã JavaScript độc hại vào trang web, khi người dùng truy cập thì mã sẽ chạy. Có ba loại XSS chính:

- Phản xạ (Reflected): mã độc nằm trong URL, phản hồi trình duyệt.
- Lưu trữ (Stored): mã độc lưu trong database, hiện thị cho nhiều người dùng.
- DOM-based: khai thác lỗ hổng trong DOM để thay đổi nội dung và thực thi mã.

E. Thực nghiệm kiểm thử xâm nhập IoT

1) Môi trường thực nghiệm và thu thập dữ liệu: Để minh họa việc áp dụng thực tế quy trình kiểm thử thâm nhập trên thiết bị IoT và router, thực nghiệm này tái hiện một môi trường mạng IoT thực tế bằng firmware OWASP IoTGoat. Mô hình thí nghiệm bao gồm ba máy ảo được triển khai trên Oracle VM VirtualBox 7.0.18:

- Attacker: Kali Linux 2025.3 (WAN)
- Target Router (R1): OWASP IoTGoat x86
- Victim: Ubuntu 20.04.6 LTS (LAN)

Mạng được cấu hình với Adapter Bridged cho phía WAN và Internal Network (inet) cho phía LAN. IoTGoat đóng vai trò là router trung tâm R1 với hai card mạng: WAN (Bridged) và LAN (Internal). Máy nạn nhân chỉ có thể truy cập internet thông qua router IoTGoat, cho phép máy tấn công giám sát và khai thác lưu lượng đi qua R1. Mô hình mạng được minh họa qua Hình 3

Máy tấn công có thể ping đến IP WAN của Router nhưng không thể truy cập trực tiếp vào dải LAN nội bộ. Máy nạn nhân có thể ping đến cả IP LAN của router và IP WAN của máy tấn công, mô phỏng môi trường mạng gia đình/văn phòng IoT điển hình.

2) Kiểm soát truy cập không đúng cách: Router IoTGoat không triển khai cơ chế khóa tài khoản, giới hạn số lần thử hoặc CAPTCHA sau nhiều lần đăng nhập sai. Sử dụng danh sách mật khẩu trích xuất từ từ điển Mirai botnet ($mirai-botnet.txt$), máy tấn công đã thực hiện tấn công brute-force trên dịch vụ SSH (cổng 8022) bằng công cụ Hydra.

Các lệnh đã sử dụng:

- Brute-force tài khoản root: `hydra -l root -P mirai-botnet_passwords.txt 192.168.100.149 ssh`
- Brute-force tài khoản iotgoatuser: lệnh tương tự với username iotgoatuser

Kết quả thu được:

- root : **1234**
- iotgoatuser: **7ujMko0vizxv**

Tấn công này nhấn mạnh nguy hiểm của mật khẩu mặc định yếu kết hợp với việc không có biện pháp ngăn chặn brute-force.

3) Khai thác thành phần lỗi thời/không an toàn: UPnP (Universal Plug and Play) là giao thức tự động cấu hình cổng, nhưng thiếu cơ chế xác thực, trở thành ví dụ điển hình của lỗ hổng "outdated components" trong thiết bị IoT.

Trên máy nạn nhân, công cụ miranda được sử dụng để quét các thiết bị hỗ trợ UPnP trong mạng LAN. Router IoTGoat được nhận diện là host số 0. Ba dịch vụ nội bộ đã được tự động forward ra ngoài như sau:

- HTTPS web admin: external 8443 $\rightarrow$ internal 443
- SSH: external 8022 $\rightarrow$ internal 22
- Backdoor: external 8515 $\rightarrow$ internal 5515

Sau khi forward thành công, máy tấn công đã truy cập được giao diện quản trị web của router thông qua địa chỉ `https://[IP_Public_Router]:8443` bằng tài khoản mặc định (root/1234). Kết quả này chứng minh UPnP có thể bị lạm dụng để phơi bày các dịch vụ quản trị nội bộ ra internet công cộng.

4) Bảo vệ quyền riêng tư không đầy đủ: IoTGoat lưu trữ log kết nối mạng dưới dạng plaintext tại `/proc/net/nf_conntrack` và bảng ARP tại `/proc/net/arp`. Sau khi SSH vào router qua cổng đã forward (8022) với tài khoản root/1234, máy tấn công có thể đọc trực tiếp toàn bộ lịch sử kết nối và hoạt động duyệt web của máy nạn nhân.

Khi máy nạn nhân truy cập các trang web như www.amazon.com, máy tấn công đã trích xuất log mới nhất và tra cứu WHOIS trên địa chỉ IP đích (ví dụ: 44.215.133.88), từ đó xác định chính xác các trang web mà người dùng đã truy cập. Điều này cho thấy router lưu trữ dữ liệu người dùng mà không mã hóa hoặc kiểm soát truy cập, cho phép bất kỳ ai chiếm được tài khoản router đều có thể theo dõi toàn bộ hoạt động của người dùng nội bộ.

VI. Nghiên cứu tình huống và bài học

A. Sự cố tấn công mạng Olympic Paris 2024

Trong Thế vận hội Paris 2024, hơn 140 cuộc tấn công mạng đã được báo cáo, chủ yếu nhắm vào các tổ chức liên quan đến

sự kiện. Các hình thức tấn công bao gồm DDoS, xâm nhập hệ thống và trộm cắp dữ liệu. Bài học rút ra là tầm quan trọng của việc diễn tập tấn công-phòng thủ toàn diện và giám sát mạng thời gian thực.

B. Sự cố rò rỉ dữ liệu của AT&T

Vào tháng 7 năm 2024, dữ liệu của khoảng 110 triệu khách hàng AT&T đã bị xâm phạm do cấu hình sai giao diện API của nhà cung cấp dịch vụ đám mây bên thứ ba. Sự cố này nhấn mạnh sự cần thiết của việc tuân thủ các nguyên tắc Zero-Trust khi làm việc với bên thứ ba và tăng cường giám sát các hoạt động xuất dữ liệu bất thường.

C. Sự cố khai thác Zero-Day Ivanti VPN

Việc phát hiện các lỗ hổng zero-day trong Ivanti Connect Secure VPN vào đầu năm 2024 đã gây ra thiệt hại lớn cho nhiều cơ quan chính phủ và tổ chức tài chính. Khoảng thời gian phát hành bản vá kéo dài đã cho phép kẻ tấn công thiết lập các kênh truy cập bền vững. Điều này cho thấy cần phải có tâm thế "Luôn giả định bị xâm nhập"(Assume Breach) trong các khung bảo mật.

VII. Kết luận và Công việc tương lai

Bài báo này đã cung cấp cái nhìn toàn diện về các thách thức và phương pháp luận hiện có trong kiểm thử xâm nhập. Qua việc thiết kế một quy trình kiểm thử sáu giai đoạn và xác thực thông qua các thực nghiệm thực tế, nghiên cứu đã chứng minh hiệu quả của việc kết hợp các công cụ chuyên dụng để nâng cao khả năng phòng thủ hệ thống.

Trong tương lai, nghiên cứu có thể tập trung vào việc tích hợp học máy và học sâu để phát triển các công cụ kiểm thử xâm nhập tự động thông minh hơn, cũng như mở rộng phạm vi kiểm thử sang các nền tảng điện toán đám mây và IoT phức tạp hơn.

Tài liệu

[1] Mariam Alhamed and MM Hafizur Rahman. A systematic literature review on penetration testing in networks: future research directions. *Applied Sciences*, 13(12):6986, 2023.

[2] Rifqi Azis and Setiadi Yazid. Pengujian kerentanan website wordpress dengan menggunakan penetration testing untuk menghasilkan website yang aman. *Jurnal Restikom: Riset Teknik Informatika Dan Komputer*, 3(3):93–105, 2021.

[3] Aileen G Bacudio, Xiaohong Yuan, Bei-Tseng Bill Chu, and Monique Jones. An overview of penetration testing. *International Journal of Network Security & Its Applications*, 3(6):19, 2011.

[4] Gelei Deng, Yi Liu, Víctor Mayoral-Vilches, Peng Liu, Yuekang Li, Yuan Xu, Tianwei Zhang, Yang Liu, Martin Pinzger, and Stefan Rass. {PentestGPT}: Evaluating and harnessing large language models for automated penetration testing. In *33rd USENIX Security Symposium (USENIX Security 24)*, pages 847–864, 2024.

[5] Dr Jason Edwards. Vulnerability assessment and penetration testing. In *Mastering cybersecurity: Strategies, technologies, and best practices*, pages 371–412. Springer, 2024.

[6] Evan Gardner, Gurmeet Singh, and Weihao Qu. Penetration testing operating systems: Exploiting vulnerabilities. In *2024 International Conference on Communications, Computing, Cybersecurity, and Informatics (CCCI)*, pages 1–9. IEEE, 2024.

[7] Chang Gong, Zhongwen Li, and Xiaoqi Li. Information security based on llm approaches: A review. *arXiv preprint arXiv:2507.18215*, 2025.

[8] Andreas Happe and Jürgen Cito. Getting pwn'd by ai: Penetration testing with large language models. In *Proceedings of the 31st ACM joint european software engineering conference and symposium on the foundations of software engineering*, pages 2082–2086, 2023.

[9] Jiaqi Huang, Yuanzheng Niu, Xiaoqi Li, and Zongwei Li. Comparative analysis of blockchain systems. *arXiv preprint arXiv:2505.08652*, 2025.

[10] Zhan Jiayan, Ma Haifei, and Chen Gengjie. Research on penetration testing procedures based on kali system. In *2023 4th International Conference on Computers and Artificial Intelligence Technology (CAIT)*, pages 271–276. IEEE, 2023.

[11] Dechao Kong, Xiaoqi Li, and Wenkai Li. Uechecker: Detecting unchecked external call vulnerabilities in dapps via graph analysis. *arXiv preprint arXiv:2508.01343*, 2025.

[12] Jin Li, Min-Huan Huang, Shuai-Bing Lu, Hu Li, and Jin-Fu Chen. Research on evaluation index system for software vulnerability analysis methods. In *2019 IEEE Fourth International Conference on Data Science in Cyberspace (DSC)*, pages 522–527. IEEE, 2019.

[13] Wenkai Li, Xiaoqi Li, Yingjie Mao, and Yuqing Zhang. Interaction-aware vulnerability detection in smart contract bytecodes. *IEEE Transactions on Dependable and Secure Computing*, 2025.

[14] Haiyang Liu, Yingjie Mao, and Xiaoqi Li. An empirical analysis of eos blockchain: Architecture, contract, and security. *arXiv preprint arXiv:2505.15051*, 2025.

[15] Yuhe Luo, Zhongwen Li, and Xiaoqi Li. Movescanner: Analysis of security risks of move smart contracts. *arXiv preprint arXiv:2508.17964*, 2025.

[16] Hengji Miao, Lei Shang, Weihong Gan, Chenle Zhang, Zhuo Guan, and Zhihong Ge. A trusted os penetration testing scheme based on metasploit and beef. In *2024 4th International Conference on Blockchain Technology and Information Security (ICBCTIS)*, pages 278–282. IEEE, 2024.

[17] Yuanzheng Niu, Xiaoqi Li, and Wenkai Li. Natlm: Detecting defects in nft smart contracts leveraging llm. *arXiv preprint arXiv:2508.01351*, 2025.

[18] Ivan K Nixon. Standard penetration test state-of-the-art report. In *Penetration Testing*, volume 1, pages 3–22. Routledge, 2021.

[19] Rajiv Pandey, Vutukuru Jyothindar, and Umesh K Chopra. Vulnerability assessment and penetration testing: a portable solution implementation. In *2020 12th International Conference on Computational Intelligence and Communication Networks (CICN)*, pages 398–402. IEEE, 2020.

[20] Kailash Kumar Pareek and Gaurav Kumar Ameta. Performance analysis of vulnerability detection tools and techniques. In *2024 Parul International Conference on Engineering and Technology (PICET)*, pages 1–5. IEEE, 2024.

[21] Hongli Peng, Wenkai Li, and Xiaoqi Li. Mining characteristics of vulnerable smart contracts across lifecycle stages. *IET Blockchain*, 5(1):e70016, 2025.

[22] Hongli Peng, Xiaoqi Li, and Wenkai Li. Multicfv: Detecting control flow vulnerabilities in smart contracts leveraging multimodal deep learning. *arXiv preprint arXiv:2508.01346*, 2025.

[23] Chengxin Shen, Zhongwen Li, Xiaoqi Li, and Zongwei Li. When blockchain meets crawlers: Real-time market analytics in solana nft markets. *arXiv preprint arXiv:2506.02892*, 2025.

[24] Yaroslav Stefinko, Andrian Piskozub, and Anatolii Obshta. Analysis of vulnerability characteristics for automated penetration testing. In *2024 IEEE 17th International Conference on Advanced Trends in Radioelectronics, Telecommunications and Computer Engineering (TCSET)*, pages 449–453. IEEE, 2024.

[25] Xin Wang and Xiaoqi Li. Ai-based vulnerability analysis of nft smart contracts. *arXiv preprint arXiv:2504.16113*, 2025.

[26] Thomas Wilhelm. *Professional penetration testing: Creating and learning in a hacking lab*. Elsevier, 2025.

[27] Yushan Xiang, Zhongwen Li, and Xiaoqi Li. Security analysis of chatgpt: Threats and privacy risks. *arXiv preprint arXiv:2508.09426*, 2025.

[28] Wei Zhang, Ju Xing, and Xiaoqi Li. Penetration testing for system security: Methods and practical approaches. *arXiv preprint arXiv:2505.19174*, 2025.

[29] Xiaoyan Zhang, Dongyang Lyu, and Xiaoqi Li. Risk assessment and security analysis of large language models. *arXiv preprint arXiv:2508.17329*, 2025.

[30] Jinxiong Zhao, Lan Yang, Chi Zhang, and Jinpeng Zhang. Research on the speed and accuracy of full port scanning. In *2023 IEEE 6th Information Technology, Networking, Electronic and Automation Control Conference (ITNEC)*, volume 6, pages 1159–1162. IEEE, 2023.

[31] Tian-yang Zhou, Yi-chao Zang, Jun-hu Zhu, and Qing-xian Wang. Nig-ap: A new method for automated penetration testing. *Frontiers of*

Information Technology & Electronic Engineering, 20(9):1277–1288, 2019.

[32] Wenwen Zhou, Dongyang Lyu, and Xiaoqi Li. Blockchain security based on cryptography: a review. *arXiv preprint arXiv:2508.01280*, 2025.

[33] Huanhuan Zou, Zongwei Li, and Xiaoqi Li. Malicious code detection in smart contracts via opcode vectorization. *arXiv preprint arXiv:2504.12720*, 2025.